

Five Questions for Any Risk Model

Laura Voicu, PhD · laura.voicu@apropos-security.com · September 2026 · v1.0

FROM THE RAW 2026 TALK “*Can you trust that number? Ten checks on the assumptions and data behind any risk model.*”

The next time someone shows you a number, a loss estimate, a frequency, a VaR, a risk score, ask these five questions before you act on it. They are drawn from a framework of ten model risk checks developed by the [Enterprise Risk Quantification Institute \(ERQI\)](#) in Model Risk Testing & Analysis for Cyber Risk Quantification.

5

QUESTIONS

10

FULL CHECKS IN THE FRAMEWORK

Any

RISK MODEL

01 Provenance and Currency

Where does the data come from, and when was it last updated?

Every source has its own biases. Insurance claims data is left-censored (losses below the retention disappear) and right-truncated (losses above the policy limit are capped). Breach notification databases depend on jurisdiction and reporting thresholds. Vendor telemetry reflects their customer base, not yours. If you cannot trace each material input to a documented source, you do not know what the model is actually measuring.

02 Sensitivity

Which inputs matter most, and how well grounded are they?

Most model outputs are driven by a handful of parameters, and the rest barely move the needle. If the top driver is an expert estimate that has never been tested against data, that is where your model risk is concentrated. Sensitivity analysis tells you where to focus your validation effort.

03 Uncertainty

What is the uncertainty band, and has anyone reported it?

When the plausible range of the frequency estimate is 2 to 5 events per year, and the severity estimate spans two orders of magnitude, the output distribution is wide enough that a point estimate can be misleading. Presenting “\$12.3 million at

the 90th percentile” without qualification creates a false sense of certainty. The primary output of model validation should be an uncertainty band, never a single point estimate.

04 Structural Omissions

What does the model leave out, and does it matter for this decision?

Every model simplifies reality. Common omissions include dependence between events, accumulation risk, and second-order effects like regulatory fines and litigation. Each omission biases the output in a direction, optimistic or pessimistic. Know which direction, and whether it changes the decision.

05 Fitness for Purpose

Is this model designed for the decision you are making?

A model sizing a \$200 million insurance program needs full uncertainty quantification and assumption challenge. A model used for internal vulnerability prioritization needs documented assumptions and periodic self-assessment. A model that is unreliable for absolute loss prediction may still be reliable for comparing alternatives: if you are ranking control investments, much of what is wrong with the model hits every option equally and cancels in the comparison. The ranking can be right when the numbers are not. Know whether the model is being used for the decision it was designed to support.

These five questions are a starting point. The full framework covers ten checks across input provenance, representativeness, staleness, structural omissions, sensitivity, false precision, implementation verification, tail reliability, conditions of use, and fitness for purpose.

The complete framework, validation catalogs, and a structured vendor assessment checklist are available in:

Enterprise Risk Quantification Institute (ERQI), Model Risk Testing & Analysis for Cyber Risk Quantification

[READ THE FULL PAPER →](#)

DOI: 10.5281/zenodo.21104266

CREATIVE COMMONS · CC BY 4.0

© 2026 Laura Voicu. This document is licensed under Creative Commons Attribution 4.0 International. You may share and adapt it for any purpose, with attribution. apropos-security.com